02 - Risk Identification and Information Gathering

1. Objective

This document aims to identify potential risks associated with the electronic patient information system and gather available information about their sources, causes, and the conditions that may allow them to occur. This provides a documented basis for subsequent risk analysis, evaluation, and treatment.

2. Scope

Risk identification is limited to the electronic patient information system defined within the project scope, including:

- Storing patient information in the database.
- Managing appointments.
- Storing and retrieving medical records from the database.
- Managing user accounts and access permissions.
- The cloud services hosting the system.

Risks are considered in terms of their potential impact on **Confidentiality, Integrity, and Availability (CIA)**, without extending the project scope to cover all other hospital systems or operations.

3. Risk Identification Methodology

Risks are identified by reviewing the system context, its functions, its users, and the parties providing related services. Potential events that may affect the system objectives are then identified.

The risk identification process includes:

1. Identifying the asset or function that may be affected.
2. Identifying the potential threat or event that could cause harm.
3. Identifying potential vulnerabilities that may allow the risk to occur.
4. Identifying the potential impact on confidentiality, integrity, or availability.

5. Gathering available information and evidence about the risk and existing controls.
6. Documenting information gaps that require verification.

Including a risk in this list does not mean that the incident has occurred or that the vulnerability necessarily exists. The scenarios below are treated as potential risks requiring further verification and analysis.

4. Initial Risk Identification

4.1 Access and User-Related Risks

Risk ID	Potential Risk Description	Affected CIA Objective(s)
R-01	An unauthorized person gains access to patient information or medical records.	Confidentiality
R-02	A user is granted permissions beyond their job requirements.	Confidentiality, Integrity
R-03	A user account is accessed by another person due to stolen or exposed login credentials.	Confidentiality, Integrity
R-04	Access remains available through an account whose owner is no longer authorized to use the system.	Confidentiality, Integrity
R-05	An authorized user misuses their permissions to access or modify patient information without proper justification.	Confidentiality, Integrity

4.2 Data and Medical Record Risks

Risk ID	Potential Risk Description	Affected CIA Objective(s)
R-06	Patient information or medical records are modified incorrectly or without authorization.	Integrity
R-07	Important medical records are deleted or lost.	Integrity, Availability
R-08	Data cannot be restored when needed because suitable backups are unavailable or restoration fails.	Integrity, Availability
R-09	Patient information is disclosed or transferred outside the system without authorization.	Confidentiality

4.3 Cybersecurity Threats and Risks

Risk ID	Potential Risk Description	Affected CIA Objective(s)
R-10	A successful phishing attack results in stolen user credentials or deceives a user into disclosing sensitive information.	Confidentiality, Integrity

R-11	A ransomware infection affects the system or a user's device, encrypting data or preventing access to it.	Availability, Integrity
R-12	A security vulnerability in the system or one of its components is exploited to gain unauthorized access or disrupt system operations.	Confidentiality, Integrity, Availability
R-13	A denial-of-service attack prevents users from accessing the system or disrupts its functions.	Availability
R-14	Malware enters the system through an infected file or program, potentially exposing, modifying, or disrupting information and system operations.	Confidentiality, Integrity, Availability

4.4 Cloud Service and Operational Risks

Risk ID	Potential Risk Description	Affected CIA Objective(s)
R-15	An outage affecting the cloud service hosting the system makes the system unavailable to users.	Availability
R-16	A cloud administration account or its associated permissions are compromised, potentially affecting the system or its data.	Confidentiality, Integrity, Availability
R-17	A technical failure in the system or one of its components prevents users from accessing the system.	Availability
R-18	Unusual activity is not detected or addressed in a timely manner, allowing an incident to continue or its impact to increase.	Confidentiality, Integrity, Availability

5. Information Gathering and Verification

Available information must be collected from appropriate sources to verify and understand the risks. These sources may include:

Information Source	Purpose
Project documents defining the system's functions, scope, and objectives	Confirm the system boundaries and intended functions.
Procedures for creating, modifying, and disabling user accounts	Understand how user access is managed.
Technical information provided by the System Administrator regarding permissions, configurations, and security controls	Verify relevant technical settings and existing controls.

Cloud service provider documentation and the service agreement	Understand the hosting service and the responsibilities of each party.
Previous incident and problem records, if available	Identify previously reported incidents and recurring problems.
Backup and recovery documentation, if available	Understand backup arrangements and recovery procedures.
Information about authentication, monitoring, and event logging, if available	Verify how access and unusual activity are monitored.
Interviews with relevant stakeholders, when necessary	Clarify operational practices and unresolved questions.

For each risk, verified information and information gaps must be documented. The existence or absence of a security control must not be assumed without supporting information.

6. Documentation of Risk Identification Results

Each risk must be documented using a unique identifier and a clear description. The record should identify the affected system objectives, potential risk source, available information, and information requiring verification.

The identified risks are consolidated in the **Risk Register** to track their status throughout the risk analysis, evaluation, treatment, and monitoring stages.

The list must be reviewed to ensure that risk descriptions are clear and duplication is minimized. Overlapping scenarios may be combined when appropriate or separated when their causes, impacts, or treatment requirements differ.

7. Stage Outputs

The outputs of this stage include:

- A documented initial list of potential risks.
- Identification of the confidentiality, integrity, and availability objectives that may be affected by each risk.
- Identification of available information sources and supporting evidence.

- Documentation of information gaps requiring verification.
- A risk list to serve as an input to the risk analysis stage.

This stage does not determine the final risk level or the decision to accept or treat a risk. These activities are performed in subsequent stages in accordance with the approved risk management methodology.